

STUDY UNIT 10

TCB and Security Principles

Trusted Computing Base · Security Principles · Secure Design

Learning Outcomes

- ✓ 10.1 Explain TCB
- ✓ 10.2 Understand how TCB achieves system security
- ✓ 10.3 Get to know guiding principles of TCB
- ✓ 10.4 Understand security principles
- ✓ 10.5 Understand secure design principles

When you are a stranger in a place, you ought to understand the dynamics of operation in that environment. The primary goal of any program of discretion in national infrastructure protection should be to ensure that information about trusted computing base (TCB) functionality, operations, and processes is not exposed inappropriately to anyone not properly authorized and to avoid disclosure to anyone who does not possess a clear business need for that information.

10.1 What is TCB?

The **Trusted Computing Base (TCB)** is the totality of hardware, software, processes, and individuals that are crucial for ensuring the overall security of a computer system. It includes all components that are critical to establishing and maintaining the security of that particular system — including system files, processes, system administrators, and mechanisms for managing and storing sensitive information.

A system with security properties will have a TCB, and the components included can vary greatly from system to system. **"Trusted" does not necessarily mean "Secure"** — it simply means that the components in the TCB are critical to the system's security.

Purpose of Trusted Computing

Trusted computing guarantees that:

- Hardware, software, and firmware elements function as designed
- A safer environment is delivered for users
- Unauthorized access and manipulation are thwarted
- Security incidents are prevented

Primary Components of a TCB

#	Component	Description
I	Hardware	Physical processors, memory, storage devices
II	Software	OS, system files, security applications
III	Enforcement Elements	All mechanisms used to enforce the security policy
IV	Security Perimeter	Boundary separating TCB from non-TCB components
V	Reference Monitor	Access control device across the security perimeter

10.2 How Does TCB Achieve Security?

A TCB consists of multiple components that work together. If any one trusted component is compromised, the entire system may fail. Before use, systems administrators test and validate the TCB, define user access to the trusted communication path, and install the operating system to enable TCB features.

The TCB achieves system security by means of:

1. Access Control (Provisioning)

Controlling who can reach what resource under what conditions — the most fundamental layer of system security.

2. Privilege Management

Granting privileges only to specific applications or processes, limiting damage from any single compromised component.

3. Authorization Enforcement

Enforcing authorization to access specific resources — identifying who you are AND what you are allowed to do.

4. Authentication

Enforcing user authentication before any access is granted. Passwords, biometrics, and tokens are examples.

5. Regular Data Backups

Taking regular data backups to ensure availability and recovery in the event of data loss or corruption.

6. Antivirus / Antimalware

Installing antivirus and antimalware software to defend against malicious code infiltrating the system.

What Does the TCB Monitor?

Input/Output Operations	I/O transactions between less secure and more secure components are monitored to prevent security lapses.
Memory	Calls or references to system memory are monitored to verify the integrity and confidentiality of data temporarily stored there.
Process Activation	In multitasking environments, file access lists, registers, and process status information are monitored to prevent data loss.
Switching of Execution Domain	Systems with interconnected domains are monitored to regulate access and prevent tampering across rings of protection.
Reference Monitor	Acts as a barrier between trusted and untrusted domains, validating access to objects by authorized subjects.
Security Kernel	Runs the necessary processes to enforce security functions and resist attacks from within the security perimeter.

The **Reference Monitor** has three distinct characteristics: (I) It cannot be bypassed and controls all access. (II) It is protected from all types of modification. (III) It is tested and verified to maintain its validity.

10.3 Guiding Principles of TCB

An effective TCB has the following characteristics:

Tamperproof	No external part of the computing system should be able to modify or tamper with the TCB's code or state. This ensures the TCB's integrity is maintained at all times.
Not Bypassable	There should be no way to bypass the TCB to breach the system's security. Every request must pass through the TCB without exception.
Verifiable	Administrators should be able to verify the TCB's correctness to ensure that its features and subsystems are secure through audits and testing.
Simple	A simple TCB is easier to verify and maintain than a complex implementation. Simplicity reduces the attack surface and makes correctness checks feasible.

TCB vs. Trusted Platform Module (TPM)

The TCB is not the same as a Trusted Platform Module (TPM). A TPM usually refers to a specific chip or specification, while TCB is a security architecture term referring to all components critical for establishing and maintaining overall system security.

Type	Security Level	Security Feature	Typical Deployment
1 — Discrete	Highest	Tamper resistant hardware	IoT devices connected to critical systems
2 — Integrated	Higher	Hardware	IoT gateways and high always-powered-on devices
3 — Firmware	High	Trusted execution environment	Low priority and low powered IoT devices
4 — Software	N/A	N/A	Testing and prototyping of IoT devices

10.4 Security Principles

Security principles are the basic guidelines that should be used when designing a secure system. Experience shows that a crucial success factor in the design of a secure system is the correct consideration of security principles.

1. Least Privilege and Separation of Duties

Least Privilege states that users should only be given the minimum amount of access necessary to perform their job. This reduces the risk of unauthorized access to sensitive data.

Separation of Duties is a system of checks and balances ensuring that no single individual has control over all aspects of a transaction. Different tasks are assigned to different people to reduce fraud and errors.

2. Defense-in-Depth

A security strategy involving **multiple layers of security controls** to protect an organization's assets. If one layer fails, others still protect the asset.

Layers can include: physical security, network security, application security, and data security — creating a resilient environment that can detect and respond to security incidents.

3. Zero Trust

A security model that assumes **all users, devices, and networks are untrusted** and must be verified before access is granted — even those inside the organization's network.

All requests for access must be authenticated, authorized, and continuously monitored. Designed to reduce the risk of data breaches by ensuring only authorized users have access.

4. Security-in-the-Open

Emphasizes the importance of security in **open source software development**. Developers must be aware of the security implications of their code.

Includes using secure coding practices, testing for vulnerabilities, using secure development tools, and collaborating with security experts.

10.5 Secure Design Principles

a) Economy of Mechanism	Keep the design as simple and small as possible. The smaller and simpler the code, the smaller the attack surface — fewer possibilities for an attacker to exploit a bug, and easier to verify correctness.
b) Fail-Safe Defaults	Base access decisions on permission rather than exclusion. Start by denying all access, then allow only what has been explicitly permitted. Use allowlists over denylists. Failures tend to deny access (noticeable and fixable) rather than silently grant unauthorized access.
c) Complete Mediation	Every access to every object must be checked for authority — there and then, every time. No relying on previous checks. This prevents TOCTTOU (Time of Check to Time of Use) attacks and promotes defense in depth.
d) Open Design	The design and code should not be considered secret. Security must depend on the secrecy of keys or passwords only — not on the secrecy of the implementation (Kerckhoff's Principle). Security by obscurity is a fundamentally fragile approach.
e) Separation of Privilege	A protection mechanism requiring two keys to unlock is more robust than one requiring only a single key. Use multi-factor authentication combining knowledge (PIN), possession (token), and biometrics (fingerprint) with different mechanisms for each factor.
f) Least Privilege	Every program and every user should operate using the least set of privileges necessary to complete the job. Grant no rights by default; add privileges one by one as needed. Equivalent to the military's 'need-to-know' rule.
g) Least Common Mechanism	Minimize subsystems shared between mutually distrusting users. Shared components create dependencies — a compromise in one area can cascade through the system like dominoes. Keep the dominoes apart; be careful with shared code and shared data.
h) Psychological Acceptability	Design security systems for ease of use for humans. If authentication is counter-intuitive, users will try to bypass it. Security and usability are in tension — find a working compromise where security is maintained but the product remains usable.

Summary

Topic	Core Idea
TCB	Complete security foundation — hardware, software, people, and processes
TCB Security Methods	Access control, authentication, authorization, privilege mgmt, backups, antimalware
TCB Principles	Tamperproof, not bypassable, verifiable, simple
Security Principles	Least privilege, defense-in-depth, zero trust, security-in-the-open
Secure Design (8)	Economy of mechanism through psychological acceptability

Self-Review Questions (SRQs)

1. What do you understand by the term TCB?
2. What are some of the TCB guiding principles?
3. Draw a table to explain at least four TPM modules.
4. How does TCB achieve security?
5. What are security principles?
6. Discuss four security principles.
7. Discuss seven secure design principles.

Glossary

TCB — Trusted Computing Base: the totality of hardware, software, processes, and individuals crucial for ensuring the overall security of a computer system.

TPM — Trusted Platform Module: a specific chip or specification (not the same as TCB) used to securely store cryptographic keys and verify OS/firmware integrity.

TOCTTOU — Time of Check to Time of Use: a class of vulnerability exploiting the gap between when a check is made and when the result is used.

MFA — Multi-Factor Authentication: authentication using two or more independent factors (knowledge, possession, biometrics).